

ACTIVE DIRECTORY BRUTE FORCE DETECTION & INVESTIGATION REPORT

Simulated Cyber Range Attack Analysis, Detection Logic Development, and SIEM Correlation Engineering

Incident ID:	INC-2026-0528A	Date/Time:	May 28, 2026 @ 17:32:47 UTC
Severity:	HIGH	Target System:	The-Server.Lab.Local (Windows Server 2019)
Investigator:	SOC Analyst / Detection Engineer	Source Artifacts:	WinEventLog:Security (4625), Splunk SIEM

1. Executive Summary

This project documentation outlines the comprehensive simulation, detection engineering, and incident investigation of a brute force authentication attack within a dedicated, segmented Security Operations Center (SOC) home lab environment.

During the exercise, an adversary machine initiated a fast-rate automated password-spraying/brute force attempt targeting Remote Desktop Protocol (RDP) entry points on the core domain infrastructure. Security events generated by the endpoint were successfully aggregated, parsed, and analyzed using centralized log pipelines and custom Splunk search queries. The monitoring configuration demonstrated 100% visibility, capturing real-time validation failures, source network attribution, and precise velocity analytics of the offensive actions.

2. Enterprise Environment Architecture

To ensure a high-fidelity enterprise operational context, a robust, segmented multi-tier enterprise network architecture was constructed using industry-standard platforms:

- **Active Directory Domain Controller:** Windows Server 2019 acting as the centralized Identity and Access Management (IAM) authority (Host: The-Server.Lab.Local).
- **SIEM Core:** Splunk Enterprise Platform responsible for centralized data ingestion, field extractions, and statistical parsing rules.
- **XDR / Endpoint Monitoring:** Wazuh Agent paired with customized Microsoft Sysmon (System Monitor) configurations for granular process-to-network tracking.
- **IDS/IPS Layer:** Suricata Network Intrusion Detection System parsing internal virtual switches.

- **Firewall / Router:** pfSense virtual appliance enforcing strict VLAN isolation between the Attacker Zone and the Protected Corporate Zone.

3. Attack Simulation Narrative

An offensive attack vector was launched from a localized Kali Linux terminal to simulate a malicious insider or compromised external footprint. The actor aimed to harvest administrative credentials via network-based password guessing.

Offensive Tooling and Execution

The threat actor used the high-performance network login cracker **Hydra (v9.6)**, targeting the Remote Desktop Protocol (RDP) endpoint exposed on the domain controller. The command structure executed was as follows:

```
kali@kali:~$ hydra -l domain_admin_account -P passwordlist.txt 192.168.30.10 rdp -V
```

The automation suite initiated a series of sequential authentication attempts against the designated target IP 192.168.30.10 utilizing a predefined password dictionary. The attack profile demonstrated the following terminal state metrics:

- **Targeted Principal:** domain_admin_account
- **Attempt Sequence:** Rapid dictionary spray including common patterns (e.g., 1234678, 12345, shire123, 44332211, 76566).
- **Observed Anomalies:** The target RDP service responded with specific state triggers indicating the accounts were valid within the directory database but not permitted or active for direct Remote Desktop access, or failed due to incorrect credentials, culminating in eventual connection failures via the underlying freerdp layer.

4. Detection Engineering & Logic

Defensive logic was anchored on Windows Security Auditing telemetry. When a network authentication attempt fails, the local Security Accounts Manager (SAM) or Active Directory Local Security Authority Subsystem Service (LSASS) records a failure event.

Core Endpoint Telemetry

The primary data source used for discovery was **Windows Event ID 4625 ("An account failed to log on")**. Review of raw logs on the local system via Windows Event Viewer revealed critical metadata patterns:

- **Logon Type 3 (Network Logon):** Confirms the connection originated across the network interface rather than an interactive console, standard for remote automated tool attacks.
- **Subject Security ID / Logon ID:** Evaluated as NULL SID (0x0), indicating that no prior valid session token existed for the process spinning up the attempt.

- **Target System Context:** The-Server.Lab.Local recorded the consecutive audit updates within fractions of a second.

5. SIEM Aggregation & Advanced Analytics

To move from simple alerting to investigative triage, all logs were routed into Splunk. Analysts implemented multi-stage queries to isolate the brute force footprint from standard network noise.

Baseline Diagnostic Query

To pull immediate events related to authentication failures on the primary host asset, the initial broad scope filter was defined:

```
index=* host="The-Server" EventCode=4625
```

Advanced Analytics and Correlation Query

To calculate attack velocity, deduce actor intent, and group alerts by the exact network origin, an advanced Splunk Search Processing Language (SPL) query was engineered:

```
index=* host="The-Server" EventCode=4625
| stats
    earliest(_time) as first_attempt
    latest(_time) as last_attempt
    dc(Account_Name) as unique_accounts_targeted
    values(Account_Name) as targeted_users
    values(Failure_Reason) as failure_reasons
    values(Logon_Type) as logon_methods
    count by Source_Network_Address
| eval duration_seconds = last_attempt - first_attempt
| eval attempts_per_second = round(count / max(duration_seconds, 1), 2)
| where count > 5
| convert ctime(first_attempt) ctime(last_attempt)
| rename Source_Network_Address as "Attacker IP", unique_accounts_targeted as "Total
Accounts Hit", targeted_users as "Targeted Accounts", failure_reasons as "Windows Error
Message", logon_methods as "Logon Type ID", attempts_per_second as "Attack Speed (eps)"
```

6. Investigation Findings & Triage Data

Executing the advanced pipeline successfully extracted a summarized correlation entry mapping the entire Hydra attack session into a single actionable row of forensic intelligence:

Attacker IP	First Attempt	Last Attempt	Total Hits	Targeted Accounts	Windows Error Message	Logon Type	Total Count	Speed (eps)
192.168.30.10	05/28/2026 17:32:47.593	05/28/2026 17:32:51.738	2	- domain_admin_account	Unknown user name or bad password.	3	10	2.41

Forensic Assessment of Captured Metrics:

- **Velocity Tracking:** The adversary hit a baseline rate of **2.41 events per second (eps)**, executing 10 structured attempts within a tight window of **4.145 seconds**. This mechanical cadence is characteristic of automated script utilities rather than standard human user errors.
- **Intent Profile:** By capturing the targeted values (including explicit attempts on the high-privilege domain_admin_account alongside structural null field initializations), the actor’s intent is clearly categorized as credential harvesting and domain escalation.

7. MITRE ATT&CK Framework Mapping

Tactical Stage	Technique ID	Technique Name	Observed Analytical Proof
Credential Access	T1110.001	Brute Force: Password Guessing	Automated high-velocity RDP authentication failures via dictionary files.
Defense Evasion	T1078.002	Valid Accounts: Domain Accounts	Explicitly targeting known high-value naming patterns (domain_admin_account).

8. Defensible Architecture Recommendations

To prevent and mitigate similar attack vectors within an enterprise network, the following remediation playbook is established:

- **Enforce Account Lockout Thresholds:** Configure Group Policy Objects (GPO) to temporarily lock accounts (e.g., 5 invalid attempts within 15 minutes) to break automated script timing windows.
- **Network Level Authentication (NLA) & Gateway Isolation:** Ensure RDP is not directly exposed to disparate subnets. Route all remote administrative traffic through an encrypted VPN tunnel or a secure remote desktop gateway server with strict Access Control Lists (ACLs).
- **Implement Multi-Factor Authentication (MFA):** Require second-factor verification on all interactive and network logon types across administrative interfaces.

- **Real-time SIEM Correlation Rule Production:** Deploy a real-time behavioral alert based on the engineered SPL script: trigger a high-severity alert whenever an internal IP creates more than 5 Event 4625 entries within 10 seconds.

9. Conclusion and Key Takeaways

This practical range project validated the importance of centralized logging architectures. Relying on local Event Viewers requires tedious manual interaction and severely hinders multi-system tracking. By centralizing Windows Security logs into an enterprise SIEM like Splunk, security teams can convert disparate logs into real-time metrics. This approach provides the precise network visibility required to rapidly detect, isolate, and neutralize active credential access threats.